

TAREA NDC02

Sistemas de Gestión de compliance.

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Contexto y alcance normativo	3
Respuestas 1	3
Apartado 2: Riesgos y obligaciones específicas	4
Respuestas 2	5
Apartado 3: Operación y evaluación del SGC	6
Respuestas 3	6

Detalles de la tarea de esta unidad

Caso práctico

Cygnus Tech Solutions, S.L. es una empresa tecnológica española con 120 empleados, con sede en Barcelona. Su negocio principal es ofrecer servicios gestionados de infraestructura cloud (IaaS) y plataformas de analítica de datos (PaaS).

Sus dos clientes principales son:

- 1. Un grupo hospitalario privado (con presencia en varias CCAA), para el que Cygnus almacena y procesa los historiales clínicos electrónicos (datos de categoría especial según RGPD).*
- 2. Una empresa fintech (entidad de dinero electrónico), que utiliza la plataforma de Cygnus para sus operaciones de pago y análisis de fraude en tiempo real.*

Cygnus Tech ha crecido muy rápido y, aunque obtuvo la certificación ISO 27001 el año pasado para ganar la confianza de sus clientes, una auditoría reciente ha señalado que su gestión del cumplimiento normativo (más allá de la seguridad de la información) es reactiva e inmadura. La dirección ha decidido implantar un SGC formal, alineado con la ISO 37301, para gestionar sus múltiples obligaciones.

Apartado 1: Contexto y alcance normativo

1.1. Identifica y justifica brevemente la aplicabilidad de tres normativas clave para Cygnus Tech. Asegúrate de incluir al menos una de las regulaciones europeas de ciberseguridad más recientes (posteriores a 2022) que comentamos, explicando por qué le aplica (dada su actividad y clientes).

1.2. Basándote en los beneficios de un SGC descritos en los materiales (ISO 37301), ¿cuáles serían los dos beneficios principales que Cygnus Tech obtendría al implementar un SGC formal, más allá de la certificación ISO 27001 que ya posee?

Respuestas 1

Respuesta 1.1

Basándonos en la información de la unidad y dada la actividad de Cygnus Tech Solutions, tres de las principales normativas serían:

- *Reglamento General de Protección de Datos (RGPD) y Ley Orgánica de Protección de Datos (LOPD):*
 - o Estas son las dos normas principales que velan por la privacidad de los datos personales y que todas las empresas deben cumplir escrupulosamente, Cygnus almacena y procesa datos de carácter personal, altamente sensibles.
- *Reglamento Europeo de Identificación Electrónica y Servicios de Confianza en el Mercado Interior (eIDAS):*
 - o El reglamento eIDAS tiene como objetivo reforzar la seguridad y la confianza de las transacciones electrónicas realizadas dentro del Mercado Único Digital Europeo y

Cygnus proporciona la plataforma para las operaciones de pago y análisis de fraude en tiempo real.

- *Reglamento DORA (Reglamento (UE) 2022/2554):*
 - o Esta normativa se aplica a la resiliencia operativa digital del sector financiero, Puesto que Cygnus Tech proporciona la plataforma (IaaS/PaaS) para las operaciones de pago y análisis de fraude en tiempo real de una empresa fintech, Cygnus Tech se convierte en un proveedor de servicios TIC crítico.

Respuesta 1.2

La implementación de un Sistema de Gestión de Cumplimiento (SGC) formal, alineado con la ISO 37301, podría proporcionar a la empresa los siguientes beneficios:

- *Minimizar o evitar sanciones judiciales, administrativas o económicas:*
 - o Un SGC permite a la compañía demostrar su diligencia y determinación en el ánimo de cumplir con la legislación. Para Cygnus, que maneja datos sanitarios altamente regulados y da soporte a servicios financieros, el incumplimiento puede acarrear graves sanciones judiciales, administrativas o económicas y estableciendo un SGC se puede minimizar o evitar cualquier responsabilidad legal.
- *Mejora de los procesos de detección de requisitos legales y y normativos que puedan surgir:*
 - o Un SGC mejora los procesos de detección de nuevos requisitos legales y normativos que puedan surgir, lo cual es vital dada la rápida evolución regulatoria en ciberseguridad de entornos de sanidad y *fintech*.

Apartado 2: Riesgos y obligaciones específicas

2.1. Describe dos riesgos de incumplimiento material (no riesgos de ciberseguridad genéricos, sino de incumplimiento legal/normativo) a los que se enfrenta Cygnus. Uno debe estar relacionado con su cliente hospitalario y el otro con su cliente fintech.

2.2. La Ley 2/2023 (reguladora de la protección de las personas que informen sobre infracciones normativas) es de obligado cumplimiento para Cygnus (120 empleados). ¿Qué obligación específica impone esta ley a la organización en materia de canales, y qué riesgo principal (o dominio de la ISO 37301) ayudaría a mitigar su correcta implementación?

Respuestas 2

Respuesta 2.1.

Podemos identificar riesgos de incumplimiento legal/normativo material basándonos en la tipología de sus clientes y la regulación mencionada en la unidad:

- Riesgo de Incumplimiento del reglamento general de protección de datos (RGPD), Cygnus manejaría datos personales sensibles debido a que uno de los cliente es un hospital, (datos de salud), y un incumplimiento en dicho reglamento podría resultar en sanciones judiciales, administrativas o económicas para la organización.
- Riesgo de Incumplimiento del reglamento DORA, aunque aplica directamente a entidades financieras, esta normativa también impone requisitos a los proveedores de servicios TIC críticos, para el sector y Cygnus es su proveedor de dichos servicios, el no cumplimiento representaría un riesgo legal y normativo que incurriría en sanciones.

Respuesta 2.2.

Dado que Cygnus cuenta con 120 empleados, está obligada al cumplimiento de la Ley 2/2023, de 20 de febrero (reguladora de la protección de las personas que informen sobre infracciones normativas), ya que esta ley es de aplicación obligatoria para todas las empresas de más de 50 trabajadores.

Como parte de la operación de la norma ISO 37301, es necesario establecer un mecanismo de denuncia y un canal de comunicación.

La Ley 2/2023, de 20 de febrero, reguladora de la protección de las personas que informen sobre infracciones normativas y de lucha contra la corrupción, traspone la Directiva 2019/1937 de la UE, conocida como la "Directiva Whistleblowing". Esta ley convierte el canal de denuncias en una **obligación legal específica** para un gran número de empresas (incluyendo todas las de más de 50 trabajadores) y para todo el sector público. Ya no es solo una buena práctica o un requisito de un estándar voluntario (como la ISO), sino una obligación legal con requisitos muy detallados sobre su gestión, confidencialidad, plazos de respuesta y protección al informante.

- La obligación específica que impone esta ley es convertir el canal de denuncias en una obligación legal específica.
- La correcta implementación del canal de denuncias ayuda a mitigar el riesgo de que la organización incurra en condenas penales o sufra sanciones judiciales, administrativas o económicas

Apartado 3: Operación y evaluación del SGC

3.1. Nombra tres partes interesadas (internas o externas) clave para el SGC de Cygnus y describe una expectativa de cumplimiento principal que tendría cada una de ellas.

3.2. Propón un control (o medida de tratamiento) específico para cada uno de los dos riesgos de incumplimiento que identificaste en la pregunta 2.1.

3.3. Define dos Indicadores Clave de Cumplimiento (KCI) que la dirección de Cygnus podría utilizar para la "Evaluación del Desempeño" (Dominio 9 de la ISO 37301) de su nuevo SGC. (Deben ser métricas, no solo tareas).

Respuestas 3

Respuesta 3.1.

Las partes interesadas de la empresa Cygnus clave y sus expectativas de cumplimiento serían:

Parte Interesada	Tipo	Expectativa de Cumplimiento Principal
1. Empleados	Interna	Ser conscientes de sus funciones y responsabilidades en relación con el compliance y recibir la política de cumplimiento, ayudando a fomentar la cultura ética en la organización
2. Clientes del Hospital	Externa	Exige el cumplimiento legal general y, específicamente, que Cygnus garantice la privacidad de los datos personales sensibles de acuerdo con el Reglamento General de Protección de Datos (RGPD) y la Ley Orgánica de Protección de Datos (LOPD).
3. Órgano de Gobierno / Dirección	Interna	Evitar condenas penales, sanciones judiciales, administrativas o económicas para la organización y sus integrantes. Además, esperan que el SGC sirva para demostrar la diligencia y determinación de la compañía en el cumplimiento.

Respuesta 3.2.

- Riesgo de Incumplimiento del reglamento general de protección de datos (RGPD)
 - o Control: Establecer un programa de formación continua con evaluación en protección de datos (RGPD/LOPD) dirigido al personal que acceda a la información del cliente hospitalario.
- Riesgo de Incumplimiento del reglamento DORA
 - o Control: Implantar procesos operativos específicos para la gestión de la resiliencia digital (según los requisitos de DORA para proveedores críticos), y revisar y probar de forma periódica dichos procedimientos para asegurar que se cumplen las obligaciones.

Respuesta 3.3.

En el dominio de evaluación de desempeño se busca medir el rendimiento de los procesos del SGC y el logro de objetivo, por lo tanto, podríamos identificar los siguientes indicadores clave de cumplimiento (KCIs) que la dirección de Cygnus podría utilizar:

- KCI: Eficacia y Revisión de Controles Críticos: El porcentaje de controles críticos para gestionar riesgos que han sido revisados y probados exitosamente durante un periodo definido (por ejemplo, anualmente).
- KCI: Cumplimiento de Plazos en la Gestión de Denuncias: El porcentaje de investigaciones de posibles fallos en los cumplimientos que son cerradas dentro del plazo legal o interno establecido. (mensual, trimestral).